GRC CASE STUDY — ISO/IEC 27005 & SWISS FADP

Initial GRC Diagnostic & Cyber Risk Analysis

Cold Chain Pharmaceutical Logistics & Storage

Organization:	Léman Froid SA (Case Study Scenario)
Recipient:	Ms. Martin, Executive Management
Business Sector:	Temperature-controlled storage & delivery of pharmaceutical products
Company Size:	32 employees
Frameworks Applied:	ISO/IEC 27005, ISO/IEC 27001, Swiss Federal Act on Data Protection (FADP)
Prepared by:	Bruno Gueuning — Junior GRC Consultant (Cybersecurity Training)

> ***Methodological Note:*** *This report is a practical Governance, Risk, and Compliance (GRC) case study conducted as part of a cybersecurity training curriculum.*

Assessment Scope: Delivery management information system, cloud-based SaaS ERP (orders, inventory, billing), cold-room temperature monitoring & SMS alerting infrastructure, third-party maintenance access, and incident governance.

1. Context & Executive Objectives

Léman Froid SA provides high-reliability cold-chain storage and delivery services for pharmaceutical products serving laboratories, clinics, and medical practices. With 32 employees, operational continuity and temperature integrity represent the core foundation of the company's business model and reputation.

Executive Management commissioned this initial GRC diagnostic to identify primary cyber risks threatening data confidentiality and delivery continuity, prioritize remediation measures, and establish an actionable, budget-aligned roadmap.

- **Key Threat Vectors:** Unauthorized ERP intrusion, ransomware or malware paralyzing logistics operations, and tampering or failure within cold-room temperature monitoring systems.
- **Systems in Scope:** Delivery routing software, SaaS ERP platform (orders, stock, invoicing), and connected temperature sensors with SMS alerting for cold storage rooms.

2. Methodology & Risk Evaluation Criteria

The assessment followed the **ISO/IEC 27005** risk management methodology aligned with **ISO/IEC 27001** controls and the **Swiss Federal Act on Data Protection (FADP / LPD)**. Information was gathered through executive interviews, technical documentation reviews, configuration checks, and consultations with department heads (Logistics, HR) and external providers (IT and refrigeration maintenance).

> **Risk Scoring Matrix (Risk = Impact × Likelihood):**
> **Impact (I):** 1 = Low | 2 = Moderate | 3 = High | 4 = Critical
> **Likelihood (L):** 1 = Low | 2 = Moderate | 3 = High | 4 = Critical
> **Risk Levels:** 1–5: Low | 6–10: Significant | 12–16: High

3. Information Gathering & Observed Facts

Twelve factual findings (F1 to F12) were documented during the discovery phase to serve as the baseline for risk scenario evaluation:

Ref.	Observed Information / Finding	Evidence Source
F1	A cloud-based SaaS ERP is used to manage customer orders, inventory, and billing.	Live demonstration
F2	The Logistics Director states that deliveries could be managed manually for up to two days.	Stakeholder interview
F3	Cold-room temperature sensors transmit continuous readings to a cloud monitoring platform.	Technical documentation
F4	Temperature excursion alerts are configured to be sent via SMS to the Warehouse Manager.	Configuration review
F5	The Warehouse Manager states that SMS alerts are consistently received.	Stakeholder interview
F6	The last documented test of the temperature alerting system dates back 18 months.	Audit report review

Ref.	Observed Information / Finding	Evidence Source
F7	The external IT provider reports that daily backups of the ERP are performed.	Stakeholder interview
F8	No backup restoration test report or written verification was presented.	Document review
F9	Three employees share a single administrator account on the delivery routing software.	Configuration review
F10	The refrigeration maintenance contractor holds remote access to cold-room control equipment.	Contract review
F11	The authentication mechanism securing this third-party remote access is not specified.	Missing documentation
F12	A paper-based procedure exists for logistics incidents, but no cyber incident response plan exists.	Document review

4. Risk Evaluation & Treatment Plan

Each scenario was evaluated for its initial risk level (**IR**) and assigned targeted treatment controls, an accountable owner, and target residual risk metrics (**L** = Target Likelihood, **I** = Target Impact, **RR** = Residual Risk).

Ref.	Risk Scenario & Business Impact	Initial Risk	Recommended Treatment	Owner	RR (L×I)
F1	**Prolonged SaaS ERP Outage:** Unauthorized access or account compromise halts orders, billing, and deliveries, causing financial loss and reputational damage.	High (16)	Audit and document all ERP user accounts and access logs; enforce strong authentication (MFA).	IT Provider	8 (2×4)
F7 / F8	**Unverified Backup Restoration:** Daily ERP backups fail to restore within 24 hours during a major outage, paralyzing business continuity.	High	Execute a full backup restoration test and deliver a dated verification report to Management.	IT Provider	8 (2×4)
F9	**Lack of Accountability:** Shared administrator credentials among three staff prevent auditability and increase privilege abuse risk.	High	Provision individual named accounts with role-based access and revoke the shared admin account.	IT Provider	3 (1×3)
F10 / F11	**Uncontrolled Vendor Remote Access:** Compromise of undocumented remote access to refrigeration controls could spoil sensitive pharmaceutical stock.	High	Maintain an authorized vendor personnel list, enforce MFA/ VPN authentication, and log remote sessions.	IT Provider & Maint.	3 (1×3)
F12	**Disorganized Crisis Response:** Absence of a paper cyber playbook wastes critical hours during a network or power blackout.	High	Draft and validate an offline (paper) cyber incident response procedure with all department heads.	Executive Mgmt	12 (3×4)

Ref.	Risk Scenario & Business Impact	Initial Risk	Recommended Treatment	Owner	RR (L×I)
F2	**Untested Manual Fallback:** Manual delivery operations fail or cause severe delays beyond 48 hours due to lack of live rehearsal.	Significant	Conduct and document a live tabletop/operational drill for manual delivery continuity.	Logistics Manager	6 (3×2)
F3–F6	**Missed Temperature Excursion Alert:** Sensor/cloud failure, unmonitored mobile phone, or outdated configuration (18 months) leads to stock loss.	Significant	Perform and document an end-to-end alert test (sensor → cloud → SMS) and define a backup on-call recipient.	Logistics & Maint.	6 (2×3)

5. Recommended Implementation Roadmap

- **Phase 1 — Immediate Priorities (Days 1 to 15):** Audit SaaS ERP access rights, execute and document the ERP backup restoration test, eliminate the shared administrator account on the routing software, and inventory/secure remote access used by the refrigeration contractor.
- **Phase 2 — Operational Continuity (Days 15 to 30):** Run a documented live exercise for manual delivery fallback operations and perform an end-to-end verification of cold-room temperature sensors and SMS alerting.
- **Phase 3 — Governance & Resilience (Days 30 to 60):** Draft, distribute, and validate the offline paper-based cyber incident management procedure across all departments.

6. Approved Budget Allocation

Out of an initial envelope of **CHF 4,000** allocated by Executive Management, **CHF 3,700** was approved for immediate deployment to safeguard core operational continuity:

Approved Priority Action	Validation	Budget (CHF)
ERP Backup Restoration Test & Documentation	Management & IT Provider	1,200.-
Documented Live Manual Delivery Continuity Drill	Management & Logistics Mgr	1,500.-
Offline Cyber Incident Management Procedure	Executive Management	1,000.-
Total Committed Budget (Phase 1)		**3,700.-**

7. Conclusion & Formal Risk Acceptance

Léman Froid SA already possesses the technical foundation required to strengthen its security posture at minimal cost. Implementing targeted governance controls and verifying existing recovery mechanisms will substantially reduce high-severity operational risks and support alignment with the **Swiss Federal Act on Data Protection (FADP)**.

Scope Limitation: This initial GRC diagnostic does not include technical penetration testing, Endpoint Detection and Response (EDR) deployment, or advanced SOC monitoring services.

Management Sign-Off & Formal Acceptance of Residual Risks:
Executive Management approves the Phase 1 risk treatment plan and budget of CHF 3,700, and formally accepts the residual risks documented above.

Date: _____ / _____ / 2026

Signature (Executive Management, Léman Froid SA):

_____